

CVE Report — Dependency Scan

Project: `vulnerable-invoice-service` · Stage 1 (Maven dependency tree + NVD CVE API) · Generated 2026-07-03 · Source: `pom.xml` @ `61ed8c3`

Summary

Metric	Count
Dependencies scanned	23
Total CVE findings	82
CRITICAL CVEs	18
HIGH CVEs	46
MEDIUM CVEs	17
LOW CVEs	1
Outdated dependencies	8
License violations	1
Supply-chain alerts	1 (typosquat, unresolvable)

NVD sourcing note: OWASP Dependency-Check's own NVD mirror sync was aborted after ~3% — no `NVD_API_KEY` and no warm `depscan-dc-data` volume were available, and a cold sync of all 345,466 NVD records would have taken 2+ hours at the unauthenticated ~5 req/30s rate. CVE/CVSS data below was instead pulled directly from the live NVD CVE API via per-dependency CPE-name queries, run concurrently — the documented fallback path — and is tagged `cvss_source: "nvd"` throughout.

Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	# CVEs	Fix version
<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8	CVE-2020-9548	9.8	CRITICAL	56	2.21.5
<code>org.apache.logging.log4j:log4j-core</code>	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	9	2.15.0 (2.25.4 clears all)
<code>org.apache.logging.log4j:log4j-api</code>	2.14.1	CVE-2021-44228 (shared NVD CPE match)*	10.0	CRITICAL	9	2.15.0 (2.25.4 clears all)
<code>com.google.protobuf:protobuf-java</code> (transitive of <code>mysql-connector-java</code>)	3.19.4	CVE-2022-3509	7.5	HIGH	4	3.25.5
<code>com.google.guava:guava</code>	24.1.1-jre	CVE-2023-2976	5.5	MEDIUM	2	32.0.0
<code>org.apache.commons:commons-lang3</code>	3.4	CVE-2025-48924	5.3	MEDIUM	1	3.18.0
<code>commons-io:commons-io</code>	2.4	CVE-2024-47554	4.3	MEDIUM	1	2.14.0

mysql:mysql-connector-java	8.0.30	— (no applicable CVE; GPL-2.0 license violation)	—	MEDIUM	0	8.0.33 (license issue persists)
----------------------------	--------	--	---	--------	---	---------------------------------

* `log4j-api` doesn't itself ship the vulnerable JNDI lookup classes (those live in `log4j-core`); NVD's shared `apache:log4j` CPE causes scanners to flag both artifacts identically.

Notable CVEs

CVE	Dependency	CVSS	Severity
CVE-2021-44228	log4j-core / log4j-api	10.0	CRITICAL
CVE-2021-45046	log4j-core / log4j-api	9.0	CRITICAL
CVE-2020-9548 / CVE-2020-9547 / CVE-2020-9546 / CVE-2020-8840 (+10 more)	jackson-databind	9.8	CRITICAL
CVE-2022-3509 / CVE-2022-3510 / CVE-2024-7254	protobuf-java (transitive)	7.5	HIGH
CVE-2026-34479 / CVE-2026-34480 / CVE-2026-34481	log4j-core / log4j-api	7.5	HIGH
CVE-2023-2976	guava	5.5	MEDIUM
CVE-2025-48924	commons-lang3	5.3	MEDIUM
CVE-2024-47554	commons-io	4.3	MEDIUM
CVE-2020-8908	guava	3.3	LOW

(*jackson-databind* alone carries 56 distinct CVEs across the RCE gadget-chain family; see `depscan-report.json` for the full itemised list.)

License violations

Dependency	License	Problem
mysql:mysql-connector-java:8.0.30	GPL-2.0 (with FOSS exception)	Copyleft license in a permissive-only (Apache/MIT/BSD) project. Suggested alternative: MariaDB Connector/J (LGPL-2.1) or the project-approved internal driver.

Supply-chain alerts

- CRITICAL — Typosquatted dependency.** `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core:jackson-databind`; the coordinate does not exist on Maven Central and fails resolution by design. This item is formally owned by the `depscan-supplychain-audit` skill but is surfaced here since it blocks a plain `dependency:tree` run. **Remove immediately.**
- HIGH — Untrusted repository.** `http://insecure-mirror.example.net/maven2` is a plain-HTTP Maven repository (MITM artifact-injection risk). Remove or replace with HTTPS.